

GITHUB

langwatch @ latest

DepGuard Security Analysis Report — 26/05/2026

Verdict: **USE WITH CAUTION**

RISK SCORE

5 / 100

Issue Backlog
High number of open issues (>500).

+5

TRUST SCORE

100 / 100

Risk Score Mirror
A risk score of 5/100 reduces trust proportionally.

-2

Active Contributors
31 contributors — healthy bus factor and diverse maintainership.

+5

Active Development
100 commits in the last 90 days — actively maintained.

+5

Executive Summary

LangWatch is a well-maintained open-source platform for LLM evaluations and AI agent testing with strong community adoption. However, the codebase includes critical post-install risks and hardcoded secrets that require immediate remediation before production use.

Repository Metadata

Owner	langwatch (Organization)
Created	09/09/2023
Last Update	26/05/2026
Commits (90d)	100
Stars	3,268
Forks	320
Open Issues	535
Contributors	31
Archived	No
Repository URL	https://github.com/langwatch/langwatch

Secure Code Review

The provided source code reveals a Go-based monorepo with multiple components, including an AI gateway and OpenTelemetry integration. The codebase is actively maintained with clear dependency management in `go.mod`. However, critical security concerns were identified: (1) A post-install script (`npx @langwatch/server`) executes arbitrary code during local setup, including downloading and installing binaries without explicit user consent. (2) Hardcoded secrets were found in the README's local setup instructions, which could expose users to credential theft. (3) The CI/CD pipeline (`clickhouse-serverless-chart.yml`) uses fixed GitHub Actions versions but lacks explicit secret scanning or dependency vulnerability checks.

STRIDE Threat Model

Overall Threat Level: **HIGH**

Spoofing

The post-install script could be spoofed if the npm package is compromised, leading to malicious binary downloads. Hardcoded secrets in local setup increase the risk of credential spoofing.

Tampering

The local setup process writes to `~/langwatch/` without integrity checks, allowing potential tampering of installed binaries or configuration files.

Repudiation

No audit logging is observed in the local setup process, making it difficult to track actions taken during installation or runtime.

Information Disclosure

Hardcoded secrets in `.env` files could be disclosed if users accidentally commit them to version control. The AI gateway may expose sensitive data if not properly configured.

Denial Of Service

Persistent background services in local setup could lead to resource exhaustion, causing denial of service on development machines.

Elevation Of Privilege

The post-install script runs with user-level permissions but could escalate privileges if the downloaded binaries are malicious or misconfigured.

License Analysis

LangWatch uses the Apache License 2.0 for most components, with enterprise modules under a commercial license.

Risk: **LOW** Commercial: YES Modify/Distribute: YES

Can: Use the software for any purpose, including commercial use, Modify and distribute the software under the same license

Cannot: Use the LangWatch trademark without permission, Hold the authors liable for damages

Must: Include the original copyright notice and license in distributions, Document changes made to the code

The Apache 2.0 license allows you to freely use, modify, and distribute LangWatch's open-source components, even for commercial purposes. You must include the original license and copyright notices. Enterprise modules require a separate commercial license for production use.

Known Vulnerabilities (0)

No known vulnerabilities found.

Suggested Alternatives

1. LangSmith (Python/TypeScript)

A platform for LLM application development, testing, and monitoring by LangChain.
Why: More mature ecosystem with tighter LangChain integration, but lacks self-hosting options and has stricter licensing for enterprise features.
License: Proprietary (free tier available) | Difficulty: MODERATE | Maintenance: ACTIVE

2. Weights & Biases Prompts (Python)

A tool for prompt engineering, versioning, and evaluation in LLM workflows.
Why: Better suited for prompt experimentation and versioning, but lacks end-to-end agent simulation features.
License: Proprietary (free tier available) | Difficulty: HARD | Maintenance: ACTIVE

3. OpenLLMetry (Python/TypeScript)

OpenTelemetry-based observability for LLM applications.
Why: Lightweight and focused on observability, but lacks evaluation and simulation features. Fully open-source with no enterprise restrictions.
License: Apache-2.0 | Difficulty: EASY | Maintenance: ACTIVE

Remediation Steps

IMMEDIATE Remove the ``npx @langwatch/server`` post-install script and replace it with explicit, documented setup steps.
This eliminates the critical supply chain risk of arbitrary code execution during installation.

IMMEDIATE Audit and document the secret generation process for ``.env`` files, ensuring cryptographically secure methods are used.
Prevents hardcoded secrets from becoming a vector for credential theft or unauthorized access.

SHORT_TERM Add user confirmation prompts for all automated install steps and implement cryptographic verification of downloaded binaries.
Reduces the risk of unintended actions during installation and ensures the integrity of downloaded artifacts.

SHORT_TERM Isolate the installation directory to a project-specific path and document all files/directories modified during installation.
Limits the impact of potential tampering and prevents unintended data loss.

LONG_TERM Implement audit logging for the local setup process and add health checks for background services.
Improves repudiation and ensures services start correctly, reducing the risk of resource exhaustion.

Token Usage & Cost

Provider / Model	mistral/mistral-large-latest
Input Tokens	8,494
Output Tokens	2,472
Total Tokens	10,966
Estimated Cost	\$0.0318